
DORA Compliance Cloud Architecture Checklist

35 control points that tell you whether your cloud architecture actually supports DORA obligations.

For CISOs, cloud architects and compliance leads • aenix.io

How to use this checklist

The Digital Operational Resilience Act (DORA, Regulation (EU) 2022/2554) is in force since 17 January 2025. It applies to most regulated financial entities operating in the EU and to the ICT third-party service providers that serve them — including cloud platforms, hosting providers, managed services, and software vendors.

This 35-point checklist gives CISOs, cloud architects, and compliance teams a structured way to assess whether their cloud architecture supports DORA obligations. It is the same starting framework Ænix uses during DORA-aligned readiness engagements with financial entities and ICT third parties.

Use it in three ways:

- 1. Self-assessment** — walk through with security, platform engineering, and compliance teams. Each unchecked box becomes a remediation item.
- 2. Supervisor dialog preparation** — the section summaries map directly to a control-narrative document.
- 3. Third-party scoping** — share with cloud / ICT vendors so they answer against the same surface (helpful for Articles 28-30 contractual review).

This checklist is an architectural readiness aid, not legal advice. DORA conformance must be confirmed by your legal counsel and validated against any sectoral or national supervisory expectations. RTS/ITS continue to evolve — refresh against the EUR-Lex consolidated text before each audit cycle.

Section coverage:

SECTION	CHECKPOINTS
1. Workload portability & exit-readiness	5 points
2. Concentration risk	4 points
3. Operational resilience	5 points
4. Sovereignty & supervisory access	5 points
5. Third-party risk & contracting	4 points
6. Risk management & incident handling	12 points

1. Workload portability & exit-readiness

DORA expects regulated entities to demonstrate they can exit an ICT provider without operational compromise. Architecture is the foundation.

- ☐ **Documented exit plan per critical workload** — tested at least every 24 months. [Art. 28\(8\)](#)
- ☐ **Workload portability is structural, not aspirational** — workloads expressible as IaC (Kubernetes manifests, Terraform, etc.) deployable to a second substrate without rewrite.
- ☐ **Vendor-locked managed services inventoried** — each one tagged replaceable / rewriteable / locked. A plan exists for "locked" items.
- ☐ **Data export tested** — customer-controlled export of all data classes (transactional, archive, secrets) verified within the stated RTO. Exit cost modeled (egress, license carry-over, parallel-run period).
- ☐ **Provider-side exit support obligations contracted** — the ICT provider contractually commits to assistance, data return, and post-termination cooperation. [Art. 30\(2\)\(d\) & 30\(3\)\(f\)](#)

A "documented exit plan" without periodic testing is a paper artifact. Regulators are increasingly asking for evidence of testing, not just existence of the document.

2. Concentration risk

DORA singles out ICT concentration risk — over-reliance on a single provider, datacenter, or jurisdiction.

- ☐ **Provider-concentration register maintained** — per critical workload: which ICT provider, which datacenter region, which sovereign jurisdiction. Updated on contract change. [Art. 28\(3\) & 29\(1\)](#)
- ☐ **Single-provider exposure quantified** — aggregate share of critical workload spend / volume per provider. Threshold defined for board review.
- ☐ **Multi-region design for critical workloads** — at minimum, two physically separate sites with independent failure domains. For tier-1 workloads, at least one site within the regulated jurisdiction.
- ☐ **Multi-supplier viability assessed** — even if not deployed today, a second supplier has been evaluated (commercial and technical) so concentration can be unwound. [Art. 28\(2\)](#)

Many financial entities discover concentration risk only when they measure it. A single hyperscaler region for "production" workloads is a common — and increasingly scrutinized — pattern.

3. Operational resilience

DORA requires proven resilience, not just designed-for resilience. Testing cadence and evidence are central.

- ☐ **RTO and RPO documented per critical workload** — with the basis of estimation (workload class, regulatory requirement, dependency analysis). [Art. 11](#)
- ☐ **Backup recovery tested in the last 12 months** — successful restore from a production backup to a clean environment. Test report retained.
- ☐ **Disaster recovery test executed** — failover to the secondary site, with measured RTO actuals, retained for supervisory review. [Art. 25](#)
- ☐ **TLPT (Threat-Led Penetration Test) conducted** — for entities in scope of TLPT (Articles 26-27): completed every 3 years, results retained, remediation tracked. [Art. 26](#)
- ☐ **Operational resilience program governed by the management body** — annual report to the board / management body. [Art. 5](#)

TLPT scoping is a major undertaking. If your entity is in scope but has not yet completed one, plan 12-18 months of preparation including provider procurement, scope agreement with the supervisor, and remediation budget.

4. Sovereignty & supervisory access

DORA presumes that supervisors can access, audit, and inspect ICT services. Architecture determines whether this is feasible.

- ☐ **Customer-controlled encryption keys for sensitive data** — including bring-your-own-key or hold-your-own-key for tier-1 workloads. Key custody document approved by the CISO. [Art. 9\(4\)\(d\)](#)
- ☐ **Audit logs immutable and exportable** — who-did-what-when log retention meeting the longest applicable requirement (often 5+ years). Tamper-evident storage. Customer-controlled export. [Art. 30\(3\)\(e\)](#)
- ☐ **Supervisor access process documented and exercised** — a procedure for granting supervisor access to systems, logs, and personnel; tested with an internal mock supervisor exercise. [Art. 28\(6\) & 30\(3\)\(e\)](#)
- ☐ **Data residency controls enforceable per workload** — workload placement constraints (EU-only, single-country, etc.) enforced by the platform, not relying on operator discipline.
- ☐ **Provider personnel access logged and reviewable** — including admin / break-glass access by ICT provider personnel, jurisdiction of access, time-limited approvals. [Art. 9\(4\)\(c\) & 30\(3\)\(e\)](#)

"Customer-controlled keys" must extend to backup, replication, and observability data — not only the primary database. A common gap is encrypted-at-rest production data with vendor-managed keys protecting the backups.

5. Third-party risk & contracting

Article 28 sets the general principles for managing ICT third-party risk and Article 30 sets the key contractual provisions between regulated entities and ICT providers — including sub-contracted ICT services.

- ☐ **ICT third-party register complete and current** — all ICT providers, including indirect (sub-contracted) ones to the second hop minimum. Updated on contract change. [Art. 28\(3\)](#)
- ☐ **Article 30 key contractual provisions present in critical-function agreements** — contract terms cover service description, access / audit rights, sub-contracting, data return, exit assistance, and termination. [Art. 30](#)
- ☐ **Sub-contracting transparency contractually enforced** — the provider must notify in advance of material changes to sub-contractors performing critical functions. [Art. 30\(2\)\(a\)](#)
- ☐ **Continuous monitoring of provider posture** — annual provider review minimum; events triggering ad-hoc review (incidents, M&A, regulatory action). [Art. 28\(2\)](#)

Existing ICT contracts signed before DORA's applicability date are not grandfathered — they must be brought into compliance. Review and renegotiate.

6. Risk management & incident handling

The largest section — covering the ICT risk management framework (Articles 5–16, esp. Art. 6) and ICT-related incident classification, reporting, and handling (Articles 17–19).

6a. Risk management framework

- ☐ **ICT risk management framework documented** — approved by the management body, reviewed at least annually. [Art. 5 & 6](#)
- ☐ **ICT asset register complete and current** — hardware, software, data, dependencies; tied to the risk register. [Art. 8](#)
- ☐ **Risk register updated continuously** — per critical workload; with owner, treatment status, residual risk. Reviewed by audit annually. [Art. 6](#)
- ☐ **Effectiveness review of ICT controls** — quarterly — documented evidence retained.
- ☐ **Cybersecurity policy approved by the management body** — refreshed annually.
- ☐ **Cybersecurity training mandatory for all staff** — including senior management; completion tracked.

Section 6 is where most gap discovery happens. Regulators look for continuous evidence, not snapshots. Use this section as input to your annual ICT risk report rather than as a one-off audit.

6b. Incident handling

DORA tightened incident classification, reporting timelines, and root-cause analysis materially compared to prior NIS / sectoral regimes.

- ☐ **24×7 detection capability for ICT-related incidents** — especially for critical workloads. Aligned with the thresholds in the RTS on incident classification. [Art. 10 & 17](#)
- ☐ **Incident classification process documented** — "significant" vs "non-significant" thresholds explicitly defined and approved. [Art. 18](#)
- ☐ **Reporting templates aligned to DORA timelines** — initial notification within hours, intermediate report within 72 hours, final report within 1 month (per Delegated Regulation (EU) 2025/301). [Art. 17-19](#)
[Delegated Reg. \(EU\) 2025/301](#)
- ☐ **Pre-established communication channels with competent authorities** — named contacts at the CSIRT, sectoral supervisor, and lead overseer. [Art. 19\(1\)](#)
- ☐ **Documented incident response with named roles** — IR plan with on-call, escalation, decision authority, and comms playbook.
- ☐ **Annual incident-response exercise** — tabletop or live; results retained and fed into framework refresh. [Art. 11](#)

Smaller financial entities sometimes assume DORA only applies to "the big banks". It applies to most regulated entities including investment firms, insurance distributors, crypto-asset service providers, and many more (see Article 2 scope).

Architecture-level recommendations

For most checkpoints, the gap is structural, not procedural. A platform built around (1) workload portability via Kubernetes-native primitives, (2) encryption at rest that you configure and whose keys you manage, (3) audit logs you can export to tamper-evident storage you control, (4) data-residency-enforceable workload placement, and (5) tested exit / restore mechanics addresses the majority of DORA's architectural surface in a single coherent design — rather than as 35 separate compensating controls.

Ænix designs platforms around this pattern. Cozystack (a CNCF project) provides the open-source foundation; Ænix Private Cloud Platform adds support with defined response times, delivery by the engineers who created Cozystack and co-maintain it, and documentation you can use in your own DORA work.

Existing platforms (VMware-based, OpenStack-based, hyperscaler-based) can usually be retrofitted partially — but DORA's portability and exit-readiness expectations are difficult to satisfy where the underlying platform is itself the source of lock-in.

Next steps

Option 1 — Self-remediate using this checklist. Assign each unchecked box to a workstream owner. Convert the unchecked boxes into a remediation plan with owners and dates.

Option 2 — Platform Readiness Assessment with Ænix (14 or 28 days). We run the checklist with you, review architecture against each control, and produce a remediation plan with effort estimates and supervisor-narrative drafts. Fixed-fee engagement.

Option 3 — Joint DORA + NIS2 + sectoral mapping. For entities in scope of multiple frameworks. We map controls across DORA, NIS2, and sectoral expectations to avoid duplicated work.

Schedule a discovery call: aenix.io/services/platform-readiness-assessment/

Refresh cadence

- **Quarterly:** review against new RTS/ITS publications and supervisory communications.
- **Annual:** structural review of checklist coverage.
- **Ad-hoc:** on material amendments to DORA itself.

Ænix created Cozystack (a CNCF project) and co-maintains it, and builds the Ænix Public Cloud, Private Cloud and AI platforms on it. aenix.io

Ænix · aenix.io · DORA Compliance Cloud Architecture Checklist · v1.2 — October 2026. Ænix created and co-maintains Cozystack (CNCF, Apache 2.0).